

BÁO CÁO THỰC HÀNH BẢO MẬT ỨNG DỤNG WEB

LAB04 · CROSS-SITE REQUEST FORGERY

Synchronizer Token · Origin/Referer · Audit & Trace

Sinh viên: Lê Minh

MSSV: 21127645

Môi trường: Flask + SQLite, chỉ chạy loopback

Ngày hoàn thiện: 15/07/2026

Mục lục

STT	Nội dung
1	Thông tin, mục tiêu và phạm vi
2	Kiến trúc, database, session và cookie
3	Nền tảng CSRF
4	Luồng vulnerable và secure
5	Token, Origin và Referer
6	SOP, SameSite và CORS
7	POST-only, logout và reset
8	Audit, trace và inspectors
9	Security Controls và Code Comparison
10	Kết quả kiểm thử, coverage và smoke test
11	Ảnh hưởng, phòng chống, giới hạn và kết luận
12	Câu hỏi báo cáo và phụ lục evidence
13	Phụ lục 10 bảng trace chi tiết

Danh mục bảng

Bảng kiến trúc và schema; Origin Matrix; audit event; state transition; security control; code comparison; kết quả test; 10 bảng trace theo từng flow.

1. Thông tin, mục tiêu và phạm vi

Lab04 là ứng dụng học tập local gồm Victim Application tại 127.0.0.1:5004 và Cross-Origin Form Demo tại 127.0.0.1:9004 hoặc localhost:9004. Mục tiêu là chỉ ra vì sao request giả mạo có thể mang theo session cookie, sau đó so sánh luồng thiếu token với luồng được bảo vệ bằng Synchronizer Token Pattern.

Phạm vi an toàn được cố định trong mã nguồn: không nhận host, URL, port hay route tùy ý; không kết nối Internet; không dùng browser automation; không dùng fetch, XMLHttpRequest, iframe hoặc document.cookie; không auto-submit. Form minh họa chỉ gửi khi người dùng chủ động bấm và xác nhận.

Báo cáo này được tạo lại từ trace JSON, request/response TXT, audit log, state transition, pytest, coverage, runtime smoke test và source code thật. Không có ảnh giả, placeholder ảnh hoặc chương ảnh trống.

- Tài khoản demo victim / Victim123! chỉ dùng cho dữ liệu local.
- Mật khẩu lưu dưới dạng hash Werkzeug; token và cookie luôn được che trong evidence.
- Hai ứng dụng bind loopback và không bật CORS wildcard.

2. Kiến trúc, database, session và cookie

Victim Application xử lý login, session, validation, SQLite mutation, audit và trace. Demo Page chỉ render ba form email cố định: vulnerable, secure thiếu token và secure token giả. Hai ứng dụng không chia sẻ secret, session hay database.

SQLite có users, demo_transfers, audit_logs, state_history và trace_records. Mọi SQL mutation dùng placeholder và transaction. State Inspector liên kết state_history với trace_id, vì vậy email trước/sau và quyết định update được kiểm tra từ dữ liệu database thật.

Flask session cookie được cấu hình HttpOnly, SameSite=Lax, path=/ và Secure=False cho HTTP loopback. HttpOnly hạn chế JavaScript đọc cookie nhưng không ngăn browser tự gắn cookie vào request; SameSite là lớp bổ sung và không thay thế token.

Data flow: Browser → Flask Router → Session Authentication → Origin/Referer → CSRF → Input Validation → SQLite → Audit/Trace → HTTP Response.

Thành phần	Nguồn dữ liệu	Vai trò
Victim	victim_app.py	Validation và mutation
Demo Page	attacker_app.py	Form local cố định
SQLite	lab04.sqlite3	State, audit, trace

3. Nền tảng CSRF

CSRF là việc lợi dụng browser của người dùng đã đăng nhập để gửi request thay đổi trạng thái mà ứng dụng nhầm là chủ ý của người dùng. Người tạo form không cần biết mật khẩu: browser quản lý cookie và tự đính kèm cookie khi chính sách cho phép.

Điều kiện điển hình gồm session còn hiệu lực, route thay đổi trạng thái, dữ liệu request có thể đoán hoặc cố định, và server không yêu cầu bằng chứng không thể giả mạo như token gắn với session. SOP có thể ngăn script đọc response nhưng không ngăn HTML form gửi request, nên không đọc được response không đồng nghĩa state không đổi.

CSRF khác XSS: CSRF ép browser gửi hành động bằng credential sẵn có, còn XSS chạy script trong trusted origin. XSS nghiêm trọng hơn đối với cơ chế CSRF vì script cùng origin có thể đọc token trong DOM và gửi request hợp lệ. Do đó CSP, escaping và phòng XSS vẫn là lớp bảo vệ thiết yếu.

- Không dùng GET cho state change vì link, prefetch, cache và crawler có thể kích hoạt.
- Token phải kiểm tra ở server vì client không phải trust boundary.
- Token không đặt trong URL để tránh history, log và Referer leak.

4. Luồng vulnerable và secure

POST /vulnerable/change-email yêu cầu session và validate email nhưng cố ý không kiểm tra Origin/Referer hoặc CSRF token. Khi form local khác origin gửi email demo_changed@lab.local và cookie hiện diện, SQLite được cập nhật, audit vulnerable_email_changed được ghi và trace mô tả nguyên nhân session-cookie-only.

POST /secure/change-email kiểm tra theo thứ tự: session, Origin hoặc Referer exact match, token hiện diện, hmac.compare_digest, email hợp lệ, rồi mới UPDATE. Sau thành công token được rotate, audit secure_email_changed/csrf_token_valid/csrf_token_rotated được ghi và response gắn với trace.

Token thiếu hoặc sai trả 403 và không đổi email. Origin sai được từ chối trước token. Các denial vẫn tạo audit và trace để cho thấy database update bị skip. Đây là khác biệt quan sát được giữa hai flow với cùng loại dữ liệu đầu vào.

Flow	Origin	Token	Kết quả
Vulnerable	Không kiểm tra	Không yêu cầu	Email có thể đổi
Secure	Exact match	Session-bound	Chỉ đổi khi mọi check đạt

5. Token, Origin và Referer

Token được sinh bằng `secrets.token_urlsafe(32)`, lưu cùng session, khác giữa hai session, tạo mới sau login và rotate sau secure state change. `validate_csrf_token` trả cấu trúc `present`, `valid`, `status` và `reason`; so sánh dùng `hmac.compare_digest`. Inspector chỉ nhận token đã mask ở server.

Origin parser dùng `urllib.parse.urlsplit` và chuẩn hóa `scheme`, `hostname`, `effective port`. Allowlist chỉ gồm `http://127.0.0.1:5004` và `http://localhost:5004`. Không dùng `substring`, `startswith` hoặc `endswith`. Nếu Origin có mặt, Origin luôn thắng; Referer chỉ là fallback khi Origin vắng; cả hai thiếu thì từ chối.

Origin và Referer là lớp bổ sung vì header có thể bị thiếu bởi chính sách trình duyệt hoặc proxy. Token vẫn là lớp chính vì nó chứng minh request biết giá trị ngẫu nhiên gắn với session.

Nguồn	Parsed	Exact match	Decision
127.0.0.1:5004	http / 127.0.0.1 / 5004	Có	Allowed
127.0.0.1:9004	http / 127.0.0.1 / 9004	Không	Denied
Missing	-	Không	Denied

6. SOP, SameSite và CORS

127.0.0.1:9004 → 127.0.0.1:5004 là cross-origin do khác port nhưng same-site do cùng scheme và host.
localhost:9004 → 127.0.0.1:5004 vừa cross-origin vừa cross-site. Báo cáo phân biệt Expected theo policy, Observed từ request thật và Not observed khi chưa dùng browser DevTools.

Same-Origin Policy kiểm soát script đọc dữ liệu cross-origin; nó không cấm form HTML gửi request. Demo chỉ giải thích lý thuyết, không dùng iframe/contentDocument và không tuyên bố tự động chứng minh SOP.

CORS điều khiển quyền script đọc response/API; form POST chuẩn không cần CORS. Vì vậy tắt CORS hoặc không bật wildcard không phải bản vá CSRF chính. SameSite phụ thuộc browser, scheme, host, method và navigation context; token server-side vẫn là lớp chính.

Nguồn → Victim	Origin	Site	Nhãn
127.0.0.1:9004	Khác	Cùng	Expected; browser chưa tự động xác minh
localhost:9004	Khác	Khác	Expected; browser chưa tự động xác minh

7. POST-only, logout và reset

Mọi secure state change dùng POST, session hợp lệ, Origin/Referer exact validation, CSRF token, input validation, audit và trace trước mutation. GET /secure/change-email chỉ render form và không đổi database. Route state-changing GET cũ đã bị loại bỏ.

POST /logout từ chối token thiếu/sai hoặc Origin không hợp lệ với HTTP 403 và giữ session. Thành công ghi logout_success trước khi session.clear. POST /reset-lab cũng từ chối trước mutation; thành công reset user/balance, giữ audit/trace/state evidence và sau đó logout.

Logout cần CSRF protection vì forced logout gây mất phiên và phá workflow. Reset cần bảo vệ mạnh hơn vì thay đổi toàn bộ trạng thái lab. HttpOnly không giúp trong hai trường hợp này vì browser vẫn có thể gửi cookie.

Route	Denied event	Success event	State rule
/logout	logout_csrf_denied	logout_success	Giữ session khi denied
/reset-lab	lab_reset_csrf_denied	lab_reset	Giữ DB khi denied

8. Audit, trace và inspectors

Audit log lưu timestamp, user_id, username, action, route, mode, Origin, Referer, CSRF status, cookie presence, decision, reason, state before/after và trace_id. Password, full cookie, full token và secret key không được ghi. Trang audit hỗ trợ filter theo action, decision, mode, username và trace ID.

Mỗi trace có request metadata thật và 16 bước: Browser UI, HTTP Request, Flask Router, Session Authentication, Origin Validation, CSRF Validation, Input Validation, SQLite Read/Write, Audit Logging, HTTP Response và Final Result. Mỗi step hiển thị timestamp, layer, title, technique, input, output, code reference, security meaning và status.

Request Inspector đọc URL, query, content metadata và form đã redaction; Cookie Inspector đọc app.config và request.cookies; Token Inspector mask ở server; Origin Inspector dùng validation result; State Inspector đọc state_history; Presentation Mode chỉ trình bày trace đã có và không gửi request.

Evidence	Số bản ghi	Nguồn
Audit	14	SQLite audit_logs
State	3	SQLite state_history
Trace flow	10	SQLite trace_records / JSON export

9. Security Controls và Code Comparison

Security Control Panel phản ánh runtime config và code: session authentication, token, rotation, Origin, Referer fallback, SameSite, HttpOnly, Secure cookie, POST-only, input validation, parameterized SQL, audit, CSP, CORS policy và request size limit. Mỗi control nêu nguồn, route, rủi ro giảm được và giới hạn.

Code Comparison dùng AST đọc source đang chạy để lấy tên file, function, line start/end và snippet. Bảng dưới đây được tạo lúc chạy generator; không phải pseudocode ghi cứng. Điều này bảo đảm nội dung báo cáo khớp với implementation cuối.

File	Function	Start	End	Source excerpt
victim_app.py	vulnerable_change_email	356	374	def vulnerable_change_email(): if request.method == "GET": return _render("vulnerable...
victim_app.py	secure_change_email	378	406	def secure_change_email(): if request.method == "GET": return _render("secure/change_...
csrf_service.py	validate_csrf_token	34	47	def validate_csrf_token(expected: str None, submitted: str None, issued_at: float None = None) -> dict:...
origin_service.py	validate_origin_or_referer	53	68	def validate_origin_or_referer(origin: str None, referer: str None = None, ...
victim_app.py	logout	301	315	def logout(): failure = _protected_route_checks("logout_csrf_denied", {}) if failure: ...
victim_app.py	reset_lab	329	352	def reset_lab(): before = _user() failure = _protected_route_checks("lab_reset_csrf_denie...

10. Kết quả kiểm thử, coverage và runtime smoke

Pytest log và coverage log dưới đây được đọc từ evidence cuối. Generator không tự tuyên bố test đạt khi log chưa tồn tại. Bộ test bao phủ route, authentication, session, CSRF, rotation, Origin/Referer, vulnerable/secure flow, logout/reset, SQLite, audit, trace, inspectors, controls, code extraction, headers, CORS, presentation, evidence, report, runtime restriction và cleanup.

Runtime smoke test khởi động hai ứng dụng loopback và chạy healthcheck, login, vulnerable email, reset hợp lệ, secure missing/invalid/origin-denied/success, logout missing và logout success. Script không kiểm tra SameSite/SOP của browser.

Pytest summary:   [82%]

[100%] 87 passed in 31.81s

Coverage summary:   [82%]

[100%] ===== tests coverage =====

_____ coverage: platform win32, python 3.12.6-final-0 _____ Name Stmts

Miss Cover Missing -----...

Smoke summary: LAB04 RUNTIME SMOKE TEST Scope: fixed localhost endpoints; no SameSite/SOP browser claim. PASS | Healthcheck Victim | HTTP 200 | expected [200] PASS | Healthcheck Demo Page | HTTP 200 | expected [200] PASS | Login victim | HTTP 303 | expected [303] PASS | Vulnerable email change | HTTP 200 | expected [200] PASS | Reset valid token | HTTP 303 | expected [303] PASS | Login after reset | HTTP 303 | expected [303] PASS...

11. Ảnh hưởng, phòng chống, giới hạn và kết luận

CSRF có thể thay đổi dữ liệu bằng quyền của nạn nhân, làm sai lệch tài khoản và gây mất tính toàn vẹn. Mức ảnh hưởng phụ thuộc route: đổi email có thể hỗ trợ chiếm quyền ở hệ thống thật; logout gây gián đoạn; reset phá trạng thái. Lab chỉ dùng dữ liệu giả lập và không cung cấp công cụ mục tiêu tùy ý.

Biện pháp chính là token ngẫu nhiên gắn session, validate ở server trước mutation và rotate sau thành công. Các lớp bổ sung gồm exact Origin/Referer, SameSite phù hợp, POST-only, input validation, re-authentication cho password/transfer, CSP, audit và trace. XSS phải được phòng riêng vì có thể làm suy yếu token.

Giới hạn: requests/test client không mô phỏng quyết định SameSite hay khả năng đọc response của browser; phần này chỉ được gắn nhãn Expected hoặc lý thuyết. Cookie Secure tắt do lab dùng HTTP loopback. Không có ảnh chụp thủ công theo phạm vi nhiệm vụ.

Kết luận: vulnerable flow chứng minh thiếu token là nguyên nhân cốt lõi; secure flow bảo vệ state bằng token + Origin/Referer + validation trước SQL. Evidence, tests, coverage và smoke test tạo chuỗi chứng minh có thể tái lập.

12. Câu hỏi báo cáo và phụ lục evidence

Browser tự gửi cookie vì cookie jar và matching policy thuộc browser. CSRF không cần biết mật khẩu vì session đã xác thực. Phía tạo form cross-origin thường không đọc được response do SOP, nhưng request vẫn có thể đổi state.

Token phải kiểm tra server-side; URL không phù hợp vì leak qua history/log/Referer. SameSite không thay token do còn same-site cross-origin và khác biệt context. HttpOnly chỉ chặn JavaScript đọc cookie, không chặn cookie được gửi.

SameSite phân loại site; SOP kiểm soát script đọc theo origin. CORS không phải bản vá chính vì form submit không cần CORS. Origin/Referer là lớp bổ sung vì có thể thiếu. Logout/reset cần token vì đều thay đổi trạng thái. XSS có thể đọc token cùng origin, nên phòng XSS là bắt buộc.

Evidence appendix gồm 10 trace JSON, 7 request TXT, 7 response TXT, audit_logs.json, state_transitions.json, pytest.txt, coverage.txt, runtime_smoke_test.txt, security_review.txt và submission_cleanup.txt. Tất cả nằm dưới evidence/ và không chứa secret đầy đủ.

Phụ lục Trace 1: Login

Trace ID: e5d30761c8a14e159f561eceab8c3933 · HTTP 303 · Decision: allowed · Origin: not_checked · CSRF: not_required

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Victim Browser	Browser prepares request	Victim Browser observation and po...	{"method":"POST","path":"/login","step":1}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	observed	Observed request data and server-side decision;...
2	Attacker Page	Form source classified	Attacker Page observation and pol...	{"method":"POST","path":"/login","step":2}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	not_applicable	Observed request data and server-side decision;...
3	Cookie Policy	Session cookie inclusion ob...	Cookie Policy observation and pol...	{"method":"POST","path":"/login","step":3}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	observed	Observed request data and server-side decision;...
4	HTTP Request	Request headers received	HTTP Request observation and poli...	{"method":"POST","path":"/login","step":4}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	observed	Observed request data and server-side decision;...
5	Flask Router	Route matched	Flask Router observation and poli...	{"method":"POST","path":"/login","step":5}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	observed	Observed request data and server-side decision;...
6	Authentication	Signed session checked	Authentication observation and po...	{"method":"POST","path":"/login","step":6}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	allowed	Observed request data and server-side decision;...
7	Origin Validation	Origin/Referer policy	Origin Validation observation and...	{"method":"POST","path":"/login","step":7}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	not_applicable	Observed request data and server-side decision;...
8	CSRF Validation	Synchronizer token policy	CSRF Validation observation and p...	{"method":"POST","path":"/login","step":8}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	not_applicable	Observed request data and server-side decision;...
9	Re-authentication	Recent authentication policy	Re-authentication observation and...	{"method":"POST","path":"/login","step":9}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	not_applicable	Observed request data and server-side decision;...
10	Input Validation	Bounded input validation	Input Validation observation and ...	{"method":"POST","path":"/login","step":10}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	allowed	Observed request data and server-side decision;...
11	Business Logic	Action decision	Business Logic observation and po...	{"method":"POST","path":"/login","step":11}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	allowed	Observed request data and server-side decision;...
12	SQLite	Database state	SQLite observation and policy dec...	{"method":"POST","path":"/login","step":12}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	unchanged	Observed request data and server-side decision;...
13	Audit Logging	Security event recorded	Audit Logging observation and pol...	{"method":"POST","path":"/login","step":13}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	recorded	Observed request data and server-side decision;...
14	HTTP Response	Response produced	HTTP Response observation and pol...	{"method":"POST","path":"/login","step":14}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	observed	Observed request data and server-side decision;...
15	Same-Origin Policy	Attacker response readabili...	Same-Origin Policy observation an...	{"method":"POST","path":"/login","step":15}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	not_applicable	Observed request data and server-side decision;...
16	Final Result	Security verdict	Final Result observation and poli...	{"method":"POST","path":"/login","step":16}	{"decision":"allowed","http_status":303,"...	victim_app.py:login_success: runtime	allowed	Observed request data and server-side decision;...

Phụ lục Trace 2: Vulnerable email

Trace ID: 2c5ff7b9f9dc439b879796c9bdc636ce · HTTP 200 · Decision: allowed · Origin: not_checked · CSRF: not_required

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Victim Browser	Browser prepares request	Victim Browser observation and po...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	observed	Observed request data and server-side decision;...
2	Attacker Page	Form source classified	Attacker Page observation and poli...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	observed	Observed request data and server-side decision;...
3	Cookie Policy	Session cookie inclusion ob...	Cookie Policy observation and poli...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	observed	Observed request data and server-side decision;...
4	HTTP Request	Request headers received	HTTP Request observation and poli...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	observed	Observed request data and server-side decision;...
5	Flask Router	Route matched	Flask Router observation and poli...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	observed	Observed request data and server-side decision;...
6	Authentication	Signed session checked	Authentication observation and po...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	allowed	Observed request data and server-side decision;...
7	Origin Validation	Origin/Referer policy	Origin Validation observation and...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	not_applicable	Observed request data and server-side decision;...
8	CSRF Validation	Synchronizer token policy	CSRF Validation observation and p...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	not_applicable	Observed request data and server-side decision;...
9	Re-authentication	Recent authentication policy	Re-authentication observation and...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	not_applicable	Observed request data and server-side decision;...
10	Input Validation	Bounded input validation	Input Validation observation and ...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	allowed	Observed request data and server-side decision;...
11	Business Logic	Action decision	Business Logic observation and po...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	allowed	Observed request data and server-side decision;...
12	SQLite	Database state	SQLite observation and policy dec...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	changed	Observed request data and server-side decision;...
13	Audit Logging	Security event recorded	Audit Logging observation and poli...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	recorded	Observed request data and server-side decision;...
14	HTTP Response	Response produced	HTTP Response observation and poli...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	observed	Observed request data and server-side decision;...
15	Same-Origin Policy	Attacker response readabili...	Same-Origin Policy observation an...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	blocked	Observed request data and server-side decision;...
16	Final Result	Security verdict	Final Result observation and poli...	{"method":"POST","path":"/vulnerable/chan...	{"decision":"allowed","http_status":200,"...	victim_app.py:vulnerable_e mail_cha...	allowed	Observed request data and server-side decision;...

Phụ lục Trace 3: Secure missing token

Trace ID: f926c4d308f649078b68148cbe1fd6c9 · HTTP 403 · Decision: denied · Origin: origin_allowed · CSRF: missing

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Victim Browser	Browser prepares request	Victim Browser observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	observed	Observed request data and server-side decision;...
2	Attacker Page	Form source classified	Attacker Page observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	not_applicable	Observed request data and server-side decision;...
3	Cookie Policy	Session cookie inclusion ob...	Cookie Policy observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	observed	Observed request data and server-side decision;...
4	HTTP Request	Request headers received	HTTP Request observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	observed	Observed request data and server-side decision;...
5	Flask Router	Route matched	Flask Router observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	observed	Observed request data and server-side decision;...
6	Authentication	Signed session checked	Authentication observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	allowed	Observed request data and server-side decision;...
7	Origin Validation	Origin/Referer policy	Origin Validation observation and...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	allowed	Observed request data and server-side decision;...
8	CSRF Validation	Synchronizer token policy	CSRF Validation observation and p...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	denied	Observed request data and server-side decision;...
9	Re-authentication	Recent authentication policy	Re-authentication observation and...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	not_applicable	Observed request data and server-side decision;...
10	Input Validation	Bounded input validation	Input Validation observation and ...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	not_reached	Observed request data and server-side decision;...
11	Business Logic	Action decision	Business Logic observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	denied	Observed request data and server-side decision;...
12	SQLite	Database state	SQLite observation and policy dec...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	unchanged	Observed request data and server-side decision;...
13	Audit Logging	Security event recorded	Audit Logging observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	recorded	Observed request data and server-side decision;...
14	HTTP Response	Response produced	HTTP Response observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	observed	Observed request data and server-side decision;...
15	Same-Origin Policy	Attacker response readabili...	Same-Origin Policy observation an...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	not_applicable	Observed request data and server-side decision;...
16	Final Result	Security verdict	Final Result observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_m issing:r...	denied	Observed request data and server-side decision;...

Phụ lục Trace 4: Secure invalid token

Trace ID: a5d4eb21ce594e0bb290f4f74b2e2f89 · HTTP 403 · Decision: denied · Origin: origin_allowed · CSRF: invalid

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Victim Browser	Browser prepares request	Victim Browser observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	observed	Observed request data and server-side decision;...
2	Attacker Page	Form source classified	Attacker Page observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	not_applicable	Observed request data and server-side decision;...
3	Cookie Policy	Session cookie inclusion ob...	Cookie Policy observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	observed	Observed request data and server-side decision;...
4	HTTP Request	Request headers received	HTTP Request observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	observed	Observed request data and server-side decision;...
5	Flask Router	Route matched	Flask Router observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	observed	Observed request data and server-side decision;...
6	Authentication	Signed session checked	Authentication observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	allowed	Observed request data and server-side decision;...
7	Origin Validation	Origin/Referer policy	Origin Validation observation and...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	allowed	Observed request data and server-side decision;...
8	CSRF Validation	Synchronizer token policy	CSRF Validation observation and p...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	denied	Observed request data and server-side decision;...
9	Re-authentication	Recent authentication policy	Re-authentication observation and...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	not_applicable	Observed request data and server-side decision;...
10	Input Validation	Bounded input validation	Input Validation observation and ...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	not_reached	Observed request data and server-side decision;...
11	Business Logic	Action decision	Business Logic observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	denied	Observed request data and server-side decision;...
12	SQLite	Database state	SQLite observation and policy dec...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	unchanged	Observed request data and server-side decision;...
13	Audit Logging	Security event recorded	Audit Logging observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	recorded	Observed request data and server-side decision;...
14	HTTP Response	Response produced	HTTP Response observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	observed	Observed request data and server-side decision;...
15	Same-Origin Policy	Attacker response readabili...	Same-Origin Policy observation an...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	not_applicable	Observed request data and server-side decision;...
16	Final Result	Security verdict	Final Result observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:csrf_token_in valid:r...	denied	Observed request data and server-side decision;...

Phụ lục Trace 5: Secure origin denied

Trace ID: 3648dbcb42dd4328adc5509a35eab2cb · HTTP 403 · Decision: denied · Origin: origin_denied · CSRF: not_required

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Victim Browser	Browser prepares request	Victim Browser observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	observed	Observed request data and server-side decision;...
2	Attacker Page	Form source classified	Attacker Page observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	observed	Observed request data and server-side decision;...
3	Cookie Policy	Session cookie inclusion ob...	Cookie Policy observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	observed	Observed request data and server-side decision;...
4	HTTP Request	Request headers received	HTTP Request observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	observed	Observed request data and server-side decision;...
5	Flask Router	Route matched	Flask Router observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	observed	Observed request data and server-side decision;...
6	Authentication	Signed session checked	Authentication observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	allowed	Observed request data and server-side decision;...
7	Origin Validation	Origin/Referer policy	Origin Validation observation and...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	denied	Observed request data and server-side decision;...
8	CSRF Validation	Synchronizer token policy	CSRF Validation observation and p...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	not_applicable	Observed request data and server-side decision;...
9	Re-authentication	Recent authentication policy	Re-authentication observation and...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	not_applicable	Observed request data and server-side decision;...
10	Input Validation	Bounded input validation	Input Validation observation and ...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	not_reached	Observed request data and server-side decision;...
11	Business Logic	Action decision	Business Logic observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	denied	Observed request data and server-side decision;...
12	SQLite	Database state	SQLite observation and policy dec...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	unchanged	Observed request data and server-side decision;...
13	Audit Logging	Security event recorded	Audit Logging observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	recorded	Observed request data and server-side decision;...
14	HTTP Response	Response produced	HTTP Response observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	observed	Observed request data and server-side decision;...
15	Same-Origin Policy	Attacker response readabili...	Same-Origin Policy observation an...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	blocked	Observed request data and server-side decision;...
16	Final Result	Security verdict	Final Result observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:origin_denied :runtime	denied	Observed request data and server-side decision;...

Phụ lục Trace 6: Secure success

Trace ID: ca5535c73e9945368316e7c918188fd4 · HTTP 200 · Decision: allowed · Origin: origin_allowed · CSRF: valid

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Victim Browser	Browser prepares request	Victim Browser observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	observed	Observed request data and server-side decision;...
2	Attacker Page	Form source classified	Attacker Page observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	not_applicable	Observed request data and server-side decision;...
3	Cookie Policy	Session cookie inclusion ob...	Cookie Policy observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	observed	Observed request data and server-side decision;...
4	HTTP Request	Request headers received	HTTP Request observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	observed	Observed request data and server-side decision;...
5	Flask Router	Route matched	Flask Router observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	observed	Observed request data and server-side decision;...
6	Authentication	Signed session checked	Authentication observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	allowed	Observed request data and server-side decision;...
7	Origin Validation	Origin/Referer policy	Origin Validation observation and...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	allowed	Observed request data and server-side decision;...
8	CSRF Validation	Synchronizer token policy	CSRF Validation observation and p...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	allowed	Observed request data and server-side decision;...
9	Re-authentication	Recent authentication policy	Re-authentication observation and...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	not_applicable	Observed request data and server-side decision;...
10	Input Validation	Bounded input validation	Input Validation observation and ...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	allowed	Observed request data and server-side decision;...
11	Business Logic	Action decision	Business Logic observation and po...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	allowed	Observed request data and server-side decision;...
12	SQLite	Database state	SQLite observation and policy dec...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	changed	Observed request data and server-side decision;...
13	Audit Logging	Security event recorded	Audit Logging observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	recorded	Observed request data and server-side decision;...
14	HTTP Response	Response produced	HTTP Response observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	observed	Observed request data and server-side decision;...
15	Same-Origin Policy	Attacker response readabili...	Same-Origin Policy observation an...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	not_applicable	Observed request data and server-side decision;...
16	Final Result	Security verdict	Final Result observation and poli...	{"method":"POST","path":"/secure/change-e...	{"decision":"allowed","http_status":200,"...	victim_app.py:secure_email_changed...	allowed	Observed request data and server-side decision;...

Phụ lục Trace 7: Logout denied

Trace ID: 1866103640d24a428b5795dd71c48fde · HTTP 403 · Decision: denied · Origin: origin_allowed · CSRF: missing

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Victim Browser	Browser prepares request	Victim Browser observation and po...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	observed	Observed request data and server-side decision;...
2	Attacker Page	Form source classified	Attacker Page observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	not_applicable	Observed request data and server-side decision;...
3	Cookie Policy	Session cookie inclusion ob...	Cookie Policy observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	observed	Observed request data and server-side decision;...
4	HTTP Request	Request headers received	HTTP Request observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	observed	Observed request data and server-side decision;...
5	Flask Router	Route matched	Flask Router observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	observed	Observed request data and server-side decision;...
6	Authentication	Signed session checked	Authentication observation and po...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	allowed	Observed request data and server-side decision;...
7	Origin Validation	Origin/Referer policy	Origin Validation observation and...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	allowed	Observed request data and server-side decision;...
8	CSRF Validation	Synchronizer token policy	CSRF Validation observation and p...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	denied	Observed request data and server-side decision;...
9	Re-authentication	Recent authentication policy	Re-authentication observation and...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	not_applicable	Observed request data and server-side decision;...
10	Input Validation	Bounded input validation	Input Validation observation and ...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	not_reached	Observed request data and server-side decision;...
11	Business Logic	Action decision	Business Logic observation and po...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	denied	Observed request data and server-side decision;...
12	SQLite	Database state	SQLite observation and policy dec...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	unchanged	Observed request data and server-side decision;...
13	Audit Logging	Security event recorded	Audit Logging observation and po...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	recorded	Observed request data and server-side decision;...
14	HTTP Response	Response produced	HTTP Response observation and po...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	observed	Observed request data and server-side decision;...
15	Same-Origin Policy	Attacker response readabili...	Same-Origin Policy observation an...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	not_applicable	Observed request data and server-side decision;...
16	Final Result	Security verdict	Final Result observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:logout_csrf_d enied:r...	denied	Observed request data and server-side decision;...

Phụ lục Trace 8: Logout success

Trace ID: c32248bcc8cd42998063011e58c8c06e · HTTP 303 · Decision: allowed · Origin: origin_allowed · CSRF: valid

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Victim Browser	Browser prepares request	Victim Browser observation and po...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	observed	Observed request data and server-side decision;...
2	Attacker Page	Form source classified	Attacker Page observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	not_applicable	Observed request data and server-side decision;...
3	Cookie Policy	Session cookie inclusion ob...	Cookie Policy observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	observed	Observed request data and server-side decision;...
4	HTTP Request	Request headers received	HTTP Request observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	observed	Observed request data and server-side decision;...
5	Flask Router	Route matched	Flask Router observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	observed	Observed request data and server-side decision;...
6	Authentication	Signed session checked	Authentication observation and po...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	allowed	Observed request data and server-side decision;...
7	Origin Validation	Origin/Referer policy	Origin Validation observation and...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	allowed	Observed request data and server-side decision;...
8	CSRF Validation	Synchronizer token policy	CSRF Validation observation and p...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	allowed	Observed request data and server-side decision;...
9	Re-authentication	Recent authentication policy	Re-authentication observation and...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	not_applicable	Observed request data and server-side decision;...
10	Input Validation	Bounded input validation	Input Validation observation and ...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	allowed	Observed request data and server-side decision;...
11	Business Logic	Action decision	Business Logic observation and po...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	allowed	Observed request data and server-side decision;...
12	SQLite	Database state	SQLite observation and policy dec...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	unchanged	Observed request data and server-side decision;...
13	Audit Logging	Security event recorded	Audit Logging observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	recorded	Observed request data and server-side decision;...
14	HTTP Response	Response produced	HTTP Response observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	observed	Observed request data and server-side decision;...
15	Same-Origin Policy	Attacker response readabili...	Same-Origin Policy observation an...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	not_applicable	Observed request data and server-side decision;...
16	Final Result	Security verdict	Final Result observation and poli...	{"method":"POST","path":"/logout","step":...	{"decision":"allowed","http_status":303,"...	victim_app.py:logout_succes s:runti...	allowed	Observed request data and server-side decision;...

Phụ lục Trace 9: Reset denied

Trace ID: 543c83f6e16f4fcb8bcdfa808bef3b6f · HTTP 403 · Decision: denied · Origin: origin_allowed · CSRF: missing

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Victim Browser	Browser prepares request	Victim Browser observation and po...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	observed	Observed request data and server-side decision;...
2	Attacker Page	Form source classified	Attacker Page observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	not_applicable	Observed request data and server-side decision;...
3	Cookie Policy	Session cookie inclusion ob...	Cookie Policy observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	observed	Observed request data and server-side decision;...
4	HTTP Request	Request headers received	HTTP Request observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	observed	Observed request data and server-side decision;...
5	Flask Router	Route matched	Flask Router observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	observed	Observed request data and server-side decision;...
6	Authentication	Signed session checked	Authentication observation and po...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	allowed	Observed request data and server-side decision;...
7	Origin Validation	Origin/Referer policy	Origin Validation observation and...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	allowed	Observed request data and server-side decision;...
8	CSRF Validation	Synchronizer token policy	CSRF Validation observation and p...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	denied	Observed request data and server-side decision;...
9	Re-authentication	Recent authentication policy	Re-authentication observation and...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	not_applicable	Observed request data and server-side decision;...
10	Input Validation	Bounded input validation	Input Validation observation and ...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	not_reached	Observed request data and server-side decision;...
11	Business Logic	Action decision	Business Logic observation and po...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	denied	Observed request data and server-side decision;...
12	SQLite	Database state	SQLite observation and policy dec...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	unchanged	Observed request data and server-side decision;...
13	Audit Logging	Security event recorded	Audit Logging observation and po...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	recorded	Observed request data and server-side decision;...
14	HTTP Response	Response produced	HTTP Response observation and po...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	observed	Observed request data and server-side decision;...
15	Same-Origin Policy	Attacker response readabili...	Same-Origin Policy observation an...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	not_applicable	Observed request data and server-side decision;...
16	Final Result	Security verdict	Final Result observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"denied","http_s tatus":403,"s...	victim_app.py:lab_reset_csrf _denie...	denied	Observed request data and server-side decision;...

Phụ lục Trace 10: Reset success

Trace ID: 08b2417e286b406d94c13d1094401bdc · HTTP 303 · Decision: allowed · Origin: origin_allowed · CSRF: valid

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	Victim Browser	Browser prepares request	Victim Browser observation and po...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	observed	Observed request data and server-side decision;...
2	Attacker Page	Form source classified	Attacker Page observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	not_applicable	Observed request data and server-side decision;...
3	Cookie Policy	Session cookie inclusion ob...	Cookie Policy observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	observed	Observed request data and server-side decision;...
4	HTTP Request	Request headers received	HTTP Request observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	observed	Observed request data and server-side decision;...
5	Flask Router	Route matched	Flask Router observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	observed	Observed request data and server-side decision;...
6	Authentication	Signed session checked	Authentication observation and po...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	allowed	Observed request data and server-side decision;...
7	Origin Validation	Origin/Referer policy	Origin Validation observation and...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	allowed	Observed request data and server-side decision;...
8	CSRF Validation	Synchronizer token policy	CSRF Validation observation and p...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	allowed	Observed request data and server-side decision;...
9	Re-authentication	Recent authentication policy	Re-authentication observation and...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	not_applicable	Observed request data and server-side decision;...
10	Input Validation	Bounded input validation	Input Validation observation and ...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	allowed	Observed request data and server-side decision;...
11	Business Logic	Action decision	Business Logic observation and po...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	allowed	Observed request data and server-side decision;...
12	SQLite	Database state	SQLite observation and policy dec...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	changed	Observed request data and server-side decision;...
13	Audit Logging	Security event recorded	Audit Logging observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	recorded	Observed request data and server-side decision;...
14	HTTP Response	Response produced	HTTP Response observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	observed	Observed request data and server-side decision;...
15	Same-Origin Policy	Attacker response readabili...	Same-Origin Policy observation an...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	not_applicable	Observed request data and server-side decision;...
16	Final Result	Security verdict	Final Result observation and poli...	{"method":"POST","path":"/reset-lab","ste...	{"decision":"allowed","http_status":303,"...	victim_app.py:lab_reset:run time	allowed	Observed request data and server-side decision;...